

# Capita Protocol: Zero-Knowledge Proofs of Cumulative Spending Compliance for Sybil-Resistant Shielded Payments Without a Registration Authority

**Yash Goel**

B.Tech, Computer Science and Engineering (Core)  
Department of Computing Technologies  
School of Computing  
College of Engineering and Technology  
SRM Institute of Science and Technology  
Kattankulathur, India 603203  
yg7728@srmist.edu.in

**Umamaheswari K. M.**

Associate Professor  
Department of Computing Technologies  
School of Computing  
College of Engineering and Technology  
SRM Institute of Science and Technology  
Kattankulathur, India 603203  
umamahek@srmist.edu.in

## Abstract

Financial regulation in both the United States and the European Union requires transaction limits to be enforced *per person*, aggregated across every account that person controls. Title 31 CFR 1010.313(b) obliges a bank to aggregate same-person currency transactions across accounts within one business day; the European digital euro proposal obliges payment service providers to enforce a per-person holding limit, and authorizes a central registry of user identifiers so that the limit can be applied across all providers. No private payment system can satisfy either rule. Systems that enforce per-user limits do so through a registration authority holding a database of enrolled identities, which reintroduces the central record that privacy technology exists to avoid; permissionless shielded pools avoid the registry but can bind limits only to accounts, and accounts are free to create, so a limit of  $T$  becomes  $nT$  for a user willing to open  $n$  wallets.

We present Capita Protocol, a construction that occupies the empty cell: cumulative per-person spending limits in a permissionless shielded pool, with no registrar, no central identity database, and no persistent linkable identifier. Three ideas combine. First, identity is derived from a government-signed electronic passport rather than issued by an operator, so the sybil bound requires no enrollment authority. Second, and centrally, the per-person running subtotal is stored as a *tally note* in the same commitment Merkle tree as monetary notes, spent and recreated by the same nullifier machinery; the per-person state therefore inherits the pool’s unlinkability instead of becoming a tracking tag. Third, every spend carries an identically shaped ciphertext to an auditor: a genuine disclosure record above the threshold, and a fixed dummy below it. The compliance mechanism therefore does not itself signal which transactions crossed the limit.

We specify the credential layer end to end, from optical capture of the machine-readable zone and PACE chip access through in-circuit verification of the ICAO Passive Authentication chain to derivation of the person secret, and we identify a leak that a naive deployment of that chain introduces: because signature algorithms correlate with issuing states, selecting a verification circuit by algorithm publishes an approximation of the holder’s nationality. We close it by witnessing the verification key under a membership proof, so enrollment presents one interface for every holder. We give game-based definitions for person-binding, limit soundness, unlinkability, and disclosure correctness, together with proof sketches, and report a working implementation in Noir over BN254 with a Grumpkin-embedded encryption gadget. The spend circuit is 8,094 UltraHonk gates and proves in 110 ms with 2.7 ms verification on commodity hardware. Proving cost below and above the disclosure threshold is measured at 110.1 ms and 110.2 ms respectively, so the uniformity on which the privacy argument depends is observable rather than assumed; costs for the passport circuits are projected from published figures for deployed systems on the same proving stack and are

labelled as such throughout. We are explicit about what is not solved, including multiple citizenship, replacement documents, borrowed documents, and populations without passports at all.

**Keywords:** zero-knowledge proofs · shielded payments · proof of personhood · regulatory compliance · spending limits · auditability · central bank digital currency

## 1 Introduction

Privacy technology for payments and financial regulation are usually presented as opposing forces, with any concrete system landing somewhere on a line between them. That framing obscures a more specific and more tractable problem. The regulations that matter here are not vague appeals to transparency; they are written rules with precise semantics, and those semantics turn out to be incompatible not with privacy in general but with one particular design choice that every deployed private payment system makes.

**Two rules that say “person.”** Title 31 of the U.S. Code of Federal Regulations, §1010.313(b), requires a financial institution to aggregate multiple currency transactions and file a report when the total exceeds the threshold *for the same person on the same business day*, across all of that person’s accounts [1]. The per-person scope is deliberate: aggregating per account would leave the rule trivially defeated by splitting funds. In December 2020, FinCEN proposed extending essentially this rule to convertible virtual currency [2]. In the European Union, the digital euro proposal obliges payment service providers to enforce a per-person holding limit (Article 16(1)), and Article 35(8) authorizes the European Central Bank, alone or jointly with national central banks, to establish a *single access point* holding digital euro user identifiers together with their associated holding limits, precisely so that the limit can be enforced across *all* providers [3]. That single access point is, in plain terms, a central registry of who holds what. The joint opinion of the European Data Protection Board and the European Data Protection Supervisor challenged it, finding that the proposal “does not sufficiently clarify the necessity and proportionality” of the processing involved, and recommending that the co-legislators specify “the technical measures that would enable a decentralised storage”. Its accompanying footnote is more explicit still: acknowledging that verifying one user’s overall holding limit may require information from several accounts, it urges that the implementation “should explore the option of using PETs that could avoid storing centrally personal data used to perform computations and take relevant decisions” [4, paras. 40–41]. That is a data protection regulator asking, in as many words, for a privacy-preserving mechanism that enforces a per-person limit without a central store of who holds what. To our knowledge, no such design has been published.

**The gap.** Consider the two families of systems that exist. Registrar-based private payment systems such as UTT [11], PRCash [8], PEReDi [10] and Platypus [9] enforce genuine per-user limits, but only because a registration authority maintains a database mapping users to credentials. That database is the artifact the technology was meant to eliminate, and it is a standing compromise, subpoena, and abuse target. Permissionless shielded pools such as Zcash [5], and the deployed pool designs that followed it, hold no identity data at all, but consequently have no notion of “person.” Any limit they impose binds to a key or an account. Opening a second wallet costs nothing, so a daily cap of  $T$  is in practice a cap of  $nT$ .

The empty cell is therefore: *person-bound limits, permissionless, no registry*. Filling it requires solving a problem that is easy to state and easy to get wrong. A person must carry cumulative state across transactions, or a limit is meaningless. But if that state is addressed by a persistent identifier, the identifier appears alongside every transaction the person makes

and links them all. The naive construction does not merely leak; it manufactures a durable pseudonym and attaches it to the payment layer, which is strictly worse for the user than the account-bound systems it was meant to improve on.

**Our approach.** Capita Protocol resolves this by refusing to give the per-person state a home of its own. The running subtotal is stored as a note in the pool’s own commitment tree, structurally indistinguishable from a monetary note, and is consumed and recreated on every spend exactly as monetary notes are. Unlinkability of the compliance state is then not a new property requiring a new argument; it is the pool’s existing note unlinkability, applied to a note that happens to hold a number instead of a balance. Sybil resistance comes from outside the system entirely: the holder derives their identity from the signature a government already placed on their passport chip, so the bound on identities per human requires no operator to enroll anyone.

## Contributions.

1. We identify per-person cumulative amount limits under permissionless operation as an unoccupied design point, and we ground it in two specific in-force legal requirements rather than in a general appeal to compliance (Sections 1 and 2).
2. We give a construction, *pool-native shielded tally notes*, in which per-person cumulative state is carried in the payment pool’s own commitment tree, and we show why the two natural alternatives (attester-managed state trees and issuer-updatable credentials) reintroduce the trusted party we set out to remove (Section 4).
3. We introduce *uniform disclosure memos*: every transaction carries an identically shaped ciphertext regardless of threshold position, closing a side channel that threshold-triggered disclosure otherwise opens. We verify uniformity empirically as well as structurally (Sections 4 and 6).
4. We give game-based definitions and proof sketches for person-binding, limit soundness, unlinkability, and disclosure correctness, including an explicit and non-obvious precondition on the threshold comparison gadget (Section 5).
5. We specify the credential layer in full rather than as an interface, covering chip access, the Passive Authentication chain, circuit decomposition and recursion, and the choice of what to bind the identity to; and we identify and close a nationality leak arising from signature-algorithm diversity that individually zero-knowledge circuits do not prevent (Section 4.2).
6. We implement the construction in Noir over BN254 and report measured circuit sizes, proving times, verification times, and proof sizes for enrollment and spend, at both threshold positions, separating these from projected passport-circuit costs (Section 6).

## 2 Related Work

The design space divides cleanly into three layers. Each is well developed in isolation. Our claim concerns their intersection.

### 2.1 Layer 1: self-sovereign personhood

Deriving a sybil-resistant identity from a government credential without involving the issuer at authentication time is established. zk-creds [19] builds anonymous credentials from ICAO electronic passports with no issuer coordination. SyRA [20] produces sybil-resilient anonymous

signatures through threshold-VRF issuance and explicitly notes anti-money-laundering applications; its pseudonyms, however, are linkable within a context, which is precisely the supercookie failure mode our design must avoid. Ring VRFs [21] support permissionless per-person rationing, and foundational treatments of proof of personhood have appeared recently [22]. A production ecosystem exists around these ideas, including zkPassport, Self, and Anon Aadhaar. None of this work applies personhood to cumulative payment limits; the outputs are one-per-person nullifiers with *count* semantics.

## 2.2 Layer 2: unlinkable cumulative accounting

Accumulating a value across unlinkable sessions is also well studied. BBA+ [23] and updatable anonymous credentials [24] let a user carry a token encoding a running total, updated unlinkably, with double-spend detection. These schemes are *key-bound*: the accumulator belongs to whoever holds the secret, and one human may hold many. They therefore provide unlinkable accounting without sybil resistance, which is exactly the half of the problem that personhood solves and they do not. On the count-based side, compact e-cash and e-token schemes [6],  $k$ -times anonymous authentication, and more recently everlasting anonymous rate-limited tokens [25], where observing more than  $N$  tokens in a single context reveals the user’s identity, all share our enforcement shape but operate on counts rather than amounts. Moving from counts to amounts is not cosmetic: a count is bounded by construction and fits a small field, whereas a monetary subtotal requires range discipline that interacts subtly with the threshold comparison, as Section 5 shows.

## 2.3 Layer 3: limits and disclosure in payment systems

Threshold-triggered disclosure in a payment system is old and, importantly, deployed. Camenisch, Hohenberger and Lysyanskaya [6] give e-cash in which anonymity holds only while the user stays below a publicly known spending limit *with any single merchant*, which makes it the closest prior work on limits over amounts rather than counts; the limit is nonetheless per merchant rather than per person, and coins are withdrawn from a bank that knows who withdrew them; Garman, Green and Miers [7] add accountable privacy to decentralized anonymous payments; PRCash [8] enforces regulator-visible limits on transaction value. Espresso’s Configurable Asset Privacy (CAP) [12] enforces in-circuit the disjunction that a viewing key is absent, or a threshold bit is set, or the memo is a correct encryption of the transaction record; it has been deployed since 2022. We do not claim novelty for threshold-triggered disclosure. Capita Protocol cites and extends this line by moving the trigger from a per-transaction predicate to a cumulative per-person one, and by requiring memo uniformity, which a per-transaction trigger does not need in the same way.

Closest to our enforcement mechanism is PayOff [17], a regulated central bank digital currency supporting private offline payments, which checks a holding limit as an in-circuit inequality on the recipient’s balance,  $\text{bal} + v \leq H$ . This is the same shape as the comparison our spend circuit performs, and it establishes that amount-based limits are enforceable inside a proof rather than only at a registrar. The limit is nonetheless bound to a single wallet’s secure element, and the system has no mechanism by which a second wallet could be recognized as belonging to the same holder, so a user who enrolls twice obtains  $2H$ . PayOff shares several authors with PRCash and Platypus, so per-wallet scoping here reflects the settled convention of a group that has repeatedly treated regulated privacy, rather than an oversight. Unlinkable policy-compliant signatures [18] widen the class of policies a payment can be required to satisfy while keeping sender and recipient unlinkable, but the achievable predicates are scoped to spending or transaction limits and assertions about *single participants*. Both works land on the account side of the distinction this paper draws: they constrain what one account may do, not what one person may do across every account they control.

|                                        | Per-person limits  | Permissionless | No identity DB |
|----------------------------------------|--------------------|----------------|----------------|
| Banking / digital euro (SAP)           | yes                | no             | no             |
| Registrar-based systems [11, 8, 10, 9] | yes                | no             | no             |
| Deployed shielded pools [5]            | account-bound only | yes            | yes            |
| Account-scoped amount limits [17, 18]  | account-bound only | no             | no             |
| Personhood systems [19, 20, 21]        | counts only        | yes            | yes            |
| Unlinkable accumulators [23, 24]       | key-bound only     | yes            | yes            |
| <b>Capita Protocol (this work)</b>     | <b>yes</b>         | <b>yes</b>     | <b>yes</b>     |

Table 1: Position relative to prior work. “Per-person limits” means cumulative monetary amounts aggregated over all accounts a single human controls.

The registrar family is broad: in addition to those already named, AQQUA [26] supports audits over a private ledger, Paxpay [27] supports regulated transfer limits and address restrictions in an asynchronous, consensus-free setting, and further designs address auditability with a designated authority [28, 29]. Every one of them obtains person-binding from a registration step. Surveys of the area [30, 31] catalogue “anonymity budget” and “operating limit” mechanisms but treat multi-account evasion and personhood only in passing, which we read as confirmation that the design point is unoccupied rather than as evidence it is uninteresting.

Finally, Friolo et al. [32] adopt as an explicit design principle that a payer should not be required to retain secrets arising from one transaction until the next, arguing that this property is essential both to reasoning about the security of asset storage and to the risk of blackmail or coercion used to extract payment history. Capita Protocol retains exactly such state, so the principle is in direct tension with our design rather than adjacent to it. We engage it in Section 7.

## 2.4 Position

Table 1 summarizes. To our knowledge, no prior system provides per-person cumulative *amount* limits under permissionless operation without a registrar.

# 3 System Model and Definitions

## 3.1 Entities

Figure 1 summarizes the entities and the paths between them.

**Person.** Holds an ICAO electronic passport whose chip data is signed by the issuing state. Derives all secrets from it. May operate arbitrarily many wallets and accounts.

**Pool.** A permissionless shielded UTXO pool: an append-only commitment Merkle tree, a nullifier set, an enrollment-nullifier set, and a current-day clock, maintained by a contract or any consensus layer. It is configured at launch with the threshold  $T$  and the auditor’s public key  $APK$ , which are policy parameters of the deployment rather than per-submission values. Holds no identity data and performs no identity checks.

**Auditor.** Holds a decryption key for disclosure memos. Honest-but-curious. Learns only disclosure records, which are pseudonymous. We treat a single key; threshold distribution across a committee is standard [29, 11] and orthogonal.

**Credential layer.** Circuits proving, in zero knowledge, that the holder possesses an ICAO electronic passport whose Passive Authentication chain terminates in a Country Signing Certification Authority key present in a public registry root. Specified in full in Section 4.2.

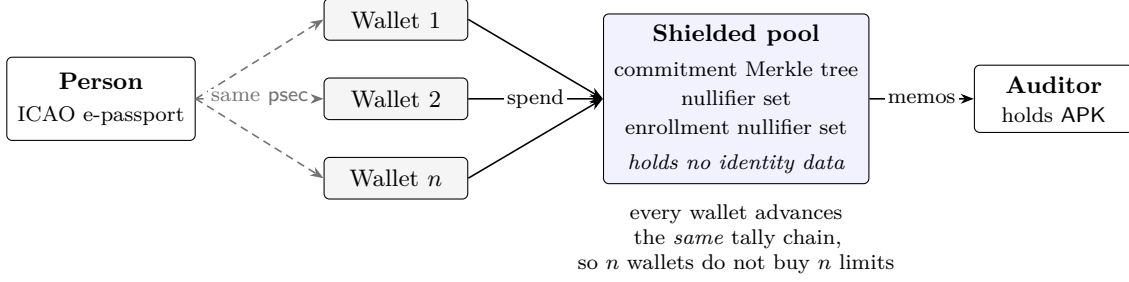


Figure 1: System model. Identity descends from a government signature the person already holds, so no party enrolls anyone. All of a person’s wallets are forced through one tally chain inside the pool, which is what makes the limit person-bound rather than account-bound. The auditor receives a memo from every spend, all of identical shape, and can decrypt them; it learns only the above-threshold records. No entity in this diagram stores a list of participants.

It writes nothing and stores nothing; the registry it reads enumerates issuing states, not people.

### 3.2 Trust and threat model

The trust root for identity is the set of government document-signing keys, the same root relied upon at every border crossing. We assume the SNARK is sound and zero-knowledge, the hash function behaves as a random oracle where modelled and is collision-resistant where used for binding, and the encryption scheme is IND-CPA. Three assumptions are specific to the credential layer and we separate them out because they are the ones a deployment can fail independently of the cryptography. *Registry correctness*: the CSCA registry root of Section 4.2.5 contains exactly the genuine issuing-state keys, so an adversary cannot introduce one of their own. *Non-cloning*: an adversary cannot extract a chip’s Active Authentication private key from tamper-resistant hardware, which bounds document duplication for issuers supporting that protocol and is simply assumed for those that do not (Section 4.2.6). *Sole possession*: the holder presenting a document is its rightful bearer. The third is the weakest of the three, since ICAO’s access control authenticates the booklet rather than the bearer, and Section 7 treats what follows from its failure. The pool operator is untrusted for privacy and trusted only for availability. The adversary sees the entire chain: all commitments, all nullifiers, all memos, all proofs, and their timing. The adversary does not hold the auditor’s decryption key; an adversary who does is considered separately in Section 7.

### 3.3 Security definitions

Let  $T$  denote the per-period threshold and let a period be a UTC business day, matching the semantics of [1].

**Definition 1** (Person-binding). For every efficient adversary  $\mathcal{A}$  controlling  $q$  distinct valid credentials and arbitrarily many wallets, the number of distinct live tally chains  $\mathcal{A}$  can maintain is at most  $q$ , except with negligible probability.

**Definition 2** (Limit soundness). For every efficient  $\mathcal{A}$  controlling  $q$  credentials and arbitrarily many accounts, if the pool accepts a set of spends whose total counted value in one period exceeds  $q \cdot T$ , then with overwhelming probability at least one accepted memo decrypts under the auditor key to a well-formed disclosure record  $(\text{pid}, s, d)$  with  $s > T$ .

**Definition 3** (Unlinkability). Consider  $\mathcal{A}$  given the full chain view but not the auditor key. For two enrolled persons  $P_0, P_1$  of  $\mathcal{A}$ ’s choosing and a challenge spend authorized by  $P_b$  for uniform

$b$ , the advantage of  $\mathcal{A}$  in guessing  $b$  is negligible. In particular this holds when the challenge spend is above threshold and  $\mathcal{A}$  observes its memo.

**Definition 4** (Disclosure correctness). For every accepted spend resulting in subtotal  $s_{\text{new}} > T$ , the accompanying memo decrypts under the auditor key to exactly  $(\text{pid}, s_{\text{new}}, d_{\text{now}})$ , the true values bound by that spend’s tally note.

## 4 Construction

### 4.1 Primitives and notation

We work over the BN254 scalar field  $\mathbb{F}_p$ .  $P_2$  denotes Poseidon2 [33], with arity part of the domain, so  $P_2$  applied to inputs of different lengths are distinct functions. Disclosure memos use hash-ElGamal over the Grumpkin curve, whose base field is the BN254 scalar field, making curve arithmetic native inside the circuit. Domain separation tags  $\text{DOM}_{\text{pay}}, \text{DOM}_{\text{tal}}, \text{DOM}_{\text{enr}}, \text{DOM}_{\text{nul}}, \text{DOM}_{\text{pass}}, \text{DOM}_{\text{dsc}}, \text{DOM}_{\text{dg1}}$  are distinct constants. Digest functions internal to the passport chain, written SHA below, are those the issuing state selected and are not interchangeable with  $P_2$ ; the credential layer must verify the state’s choice rather than substitute a proof-friendly alternative.

### 4.2 The credential layer

Sybil resistance in Capita Protocol rests entirely on a signature the holder’s government has already produced and placed on their passport chip. Because that signature is the trust root for the whole construction, we specify the path from the physical document to the field element `psec` in full. Nothing in this subsection is novel cryptography; the contribution is the choice of what to bind to and the observation, in Section 4.2.7, that naive deployment of an otherwise standard verification chain leaks the holder’s nationality.

#### 4.2.1 The document and its signature chain

ICAO Doc 9303 [13] specifies the Logical Data Structure carried by the contactless chip in an electronic passport. The chip exposes numbered data groups, of which two matter here: DG1 holds the machine-readable zone (MRZ) exactly as printed on the data page, and DG15 holds an Active Authentication public key where the issuer supports that option. Alongside them sits the Document Security Object (SOD), which is what makes the document self-authenticating.

The SOD is a CMS `SignedData` structure [14]. Its encapsulated content is an ASN.1 `LDSSecurityObject` listing, for every data group present, the digest of that group under a stated hash algorithm. The signed attributes include a `messageDigest` attribute holding the digest of that encapsulated content, and the signature is computed over the DER encoding of those signed attributes using the private key of a Document Signer. The corresponding Document Signer Certificate (DSC) is carried inside the SOD, and the DSC is itself signed by the issuing state’s Country Signing Certification Authority (CSCA).

Passive Authentication is the verification of that chain, and it is a chain of four links:

$$\text{DG1} \xrightarrow{\text{digest}} \text{LDSSecurityObject} \xrightarrow{\text{digest}} \text{signedAttrs} \xrightarrow{\sigma_{\text{DS}}} \text{DSC} \xrightarrow{\sigma_{\text{CSCA}}} \text{pk}_{\text{CSCA}}.$$

Verifying every link establishes that the issuing state attests to the exact MRZ bytes in DG1. Figure 2 shows the chain together with the circuit boundaries we impose on it.

#### 4.2.2 Reading the chip

Chip access is deliberately gated on physical possession of the booklet. The holder first captures the MRZ optically from the data page. For the TD3 format used by passports this is two lines of

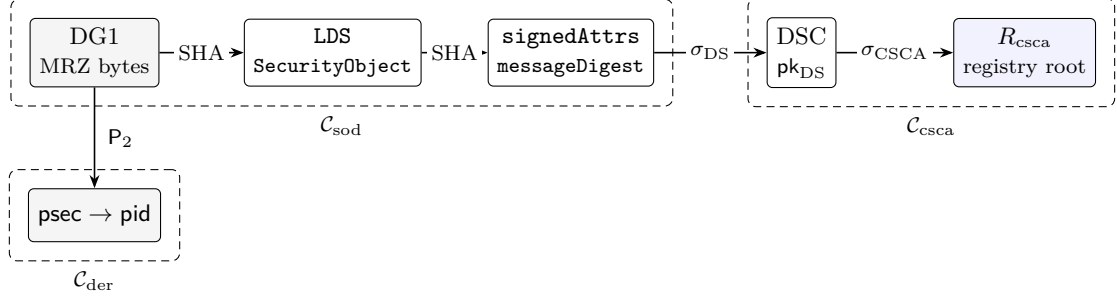


Figure 2: Passive Authentication as the credential layer proves it. Reading left to right is the ICAO chain: the digest of the MRZ appears in the security object, whose digest appears in the signed attributes, which the Document Signer signs, under a certificate the issuing state’s CSCA signs. Only the rightmost box is public; every other value is a private witness. The three dashed regions are the circuits of Section 4.2.3, composed recursively so that enrollment presents a single proof with one verification key for every holder, whatever their document’s algorithm.

forty-four characters, from which the access key is derived over the concatenation of document number, date of birth, and expiry date, each with its check digit.

Two access protocols are in use. Basic Access Control derives a seed from the SHA-1 digest of that concatenation and establishes a Triple-DES secure messaging channel. Password Authenticated Connection Establishment (PACE) instead runs a password-authenticated Diffie–Hellman exchange keyed on the same MRZ material, and is mandatory for documents issued under the current specification; it removes the offline dictionary attack that Basic Access Control admits against a recorded session. Either way the reader obtains a secure messaging channel over which it selects the passport application and reads DG1, DG15 where present, and the SOD.

Two consequences follow, and both are properties of ICAO’s design rather than of ours. First, an adversary who has never physically held the booklet cannot read the chip, because the access key is printed inside it. Second, and less comfortably, an adversary who *has* held it can, since the protocol authenticates the document rather than its bearer. We return to this in Section 7.

#### 4.2.3 What the circuit proves

A single monolithic circuit over the whole chain would be both large and inflexible, because the two signature verifications use whatever algorithm the issuing state chose. We therefore split the statement into three circuits and compose them recursively.

$\mathcal{C}_{\text{csca}}$  (**trust anchor**). Proves that the embedded DSC carries a valid signature under some  $\text{pk}_{\text{CSca}}$  that is a member of the CSCA registry root  $R_{\text{csca}}$  of Section 4.2.5. It outputs the binding commitment  $h_{\text{dsc}} = P_2(\text{DOM}_{\text{dsc}}, \text{pk}_{\text{DS}})$  and reveals neither certificate.

$\mathcal{C}_{\text{sod}}$  (**document integrity**). Takes  $h_{\text{dsc}}$  as a public input, and proves that  $\sigma_{\text{DS}}$  verifies over **signedAttrs** under the committed  $\text{pk}_{\text{DS}}$ , that the **messageDigest** attribute equals the digest of the encapsulated **LDSSecurityObject**, and that the digest of the witnessed DG1 bytes equals the DG1 entry within it. It outputs  $h_{\text{dg1}} = P_2(\text{DOM}_{\text{dg1}}, \text{DG1})$ .

$\mathcal{C}_{\text{der}}$  (**derivation**). Takes  $h_{\text{dg1}}$ , reproduces the field parse of Section 4.2.4 from the same witnessed DG1 bytes, and derives **psec** and then **pid**. This circuit is where our protocol begins, and it is the only one of the three that is independent of the issuing state’s algorithm choices.



The split earns three things. The trust-anchor proof depends only on the DSC, which is fixed for the life of the document, so it is generated once and cached rather than recomputed per transaction. Only the first two circuits need per-algorithm variants, leaving the protocol-specific logic untouched as the variant set grows. And because  $\mathcal{C}_{\text{der}}$  consumes a commitment rather than raw certificate material, the enrollment circuit of Section 4.4 aggregates the chain into one proof whose public interface is a single field element.

#### 4.2.4 Deriving the person secret

The MRZ carries both document attributes and personal attributes, and the choice between them is the one genuine design decision in this subsection. We bind to the document:

$$\text{psec} = P_2(\text{DOM}_{\text{pass}}, \text{state}, \text{docnum}), \quad \text{pid} = P_2(\text{psec}, \text{APP\_SCOPE}),$$

where *state* is the three-character issuing-state code and *docnum* the nine-character document number, each packed into a single field element as big-endian ASCII; twenty-four and seventy-two bits respectively sit far below the 254-bit capacity of  $\mathbb{F}_p$ , so the packing is injective without further encoding. Namespacing the document number by issuing state is what makes the pair globally unique, since document numbers are only unique within an issuer. Scoping by APP\_SCOPE means the identifier this deployment sees is unlinkable to the identifier the same passport yields anywhere else. Neither value is revealed to any party at any point.

Binding to the document rather than to the person is a trade, and it is worth stating both sides. Personal attributes, meaning name, date of birth, sex and nationality, survive renewal, but they collide: two people sharing a name, a birth date, a sex and a nationality would share a *psec*, and in populous states that is not a hypothetical. A collision is strictly worse than a duplicate, because the two holders would silently share and corrupt one tally chain. Document binding admits the converse failure instead: renewal produces a new document number, hence a new *pid*, hence a fresh limit. We accept that failure because it is rate-limited by the issuing state rather than by us, it costs a genuine passport application, and it leaves an administrative trail, whereas a collision is silent and unfixable. Section 7 treats the replacement-by-loss-report variant of the attack, which is faster than waiting for expiry.

#### 4.2.5 The CSCA registry and its trust assumption

$\mathcal{C}_{\text{csca}}$  checks membership in a Merkle root over the set of trusted CSCA public keys. Those keys are published through the ICAO Public Key Directory and through the signed CSCA master lists that participating states issue, so the set is a public artifact and the root over it is reproducible by anyone from the same inputs. States rotate CSCA keys on a multi-year cycle with deliberately overlapping validity, so the registry is append-mostly and a rotation does not invalidate documents already in circulation.

This is a trust assumption and we name it as such: a registry root that admits an adversarial key admits forged identities wholesale. What it is not, however, is a registrar, and the distinction is the one the paper turns on. The registry enumerates *issuing states*, of which there are on the order of two hundred. It contains no entry per person, it grows only when a state rotates a key, and no act of enrollment writes to it. An adversary who compromises it gains the ability to mint identities but learns nothing whatsoever about any existing holder, because there is nothing about holders in it to learn. A registrar database inverts both properties.

#### 4.2.6 Cloning, and what Passive Authentication does not prove

Passive Authentication proves that the data is genuinely signed. It does not prove that the chip presenting the data is the chip the signature was issued for, because a byte-for-byte copy of DG1 and the SOD verifies exactly as the original does. ICAO addresses this with two optional

protocols. Active Authentication has the chip sign a reader-supplied challenge under a private key whose public counterpart sits in DG15, and Chip Authentication performs an ephemeral-static Diffie–Hellman against a key in DG14; either demonstrates that the chip holds a private key that a passive copy of the data groups does not carry.

Where the issuer supports Active Authentication, our enrollment circuit takes the challenge response as an additional conjunct, proving in zero knowledge that a valid response exists under the DG15 key that the SOD attests. This raises the bar from copying published bytes to extracting a key from tamper-resistant hardware. It does not eliminate the attack, and support is not universal, so we state non-cloning as an explicit assumption in Section 5 rather than a derived property.

#### 4.2.7 Algorithm diversity, and a leak it creates

Issuing states do not agree on signature algorithms. Documents in circulation use RSA under PKCS#1 v1.5 and under PSS at 2048, 3072 and 4096 bits, and ECDSA over the NIST P-256 and P-384 curves and over several Brainpool curves, paired with digests from SHA-1 through SHA-512. A deployment therefore carries a family of variants of  $\mathcal{C}_{\text{cscs}}$  and  $\mathcal{C}_{\text{sod}}$ , one per algorithm pairing it supports.

The obvious deployment of that family leaks. If the variant is selected by verification key at verification time, the key identifies the algorithm, the algorithm correlates strongly with the issuing state, and every enrollment therefore publishes an approximation of its holder’s nationality. For a system whose entire purpose is to avoid attaching durable attributes to payments, shipping that would be self-defeating, and it is not obvious from the construction: each variant is individually zero-knowledge, and the leak lives in the choice among them rather than in any one of them.

We close it with the same mechanism the construction already uses elsewhere. The enrollment circuit verifies an inner proof under a verification key supplied as a private witness, together with a Merkle proof that the key belongs to the published set of admitted variants. The outer proof then has one verification key for every holder regardless of document origin, and the observable interface of enrollment is identical for all of them. This is the credential-layer analogue of the uniform disclosure memos of Section 4.6: in both cases a mechanism that is sound but shape-revealing is made uniform, because in this setting shape is itself the leak.

### 4.3 Notes

Two note types share one commitment tree:

$$\begin{aligned} \text{payment note } (v, \text{pk}, r) : \quad & \text{PayCom} = \text{P}_2(\text{DOM}_{\text{pay}}, v, \text{pk}, r), \quad \text{pk} = \text{P}_2(\text{sk}), \\ \text{tally note } (\text{pid}, s, d, r) : \quad & \text{TalCom} = \text{P}_2(\text{DOM}_{\text{tal}}, \text{pid}, s, d, r). \end{aligned}$$

Nullifiers are  $\text{Nul}(\text{secret}, C) = \text{P}_2(\text{DOM}_{\text{nul}}, \text{secret}, C)$ , where *secret* is *sk* for a payment note and *psec* for a tally note. Distinct domain tags are load-bearing: without them a payment note could be reinterpreted as a tally note of different arity, collapsing the two accounting systems into one.

### 4.4 Enrollment

Enrollment happens once per person and is the only point at which the credential layer is exercised. The circuit takes the recursive proof of Section 4.2.3 as a witness and proves, in one statement:

1. **Credential validity.** The inner proof verifies under a verification key *vk* supplied as a private witness, together with a Merkle proof that *vk* is a member of the published root

$R_{vk}$  of admitted algorithm variants. Per Section 4.2.7, witnessing rather than publishing  $vk$  is what keeps enrollment from advertising the holder’s issuing state.

2. **Anti-cloning, where available.** If the document carries a DG15 key, a valid Active Authentication response over that key is proven as an additional conjunct, binding the enrollment to a chip that holds a private key rather than to a copy of published bytes.
3. **Derivation.**  $psec$  is recomputed from the DG1 bytes the inner proof committed to, and  $pid = P_2(psec, APP\_SCOPE)$  from it. Recomputation matters for the same reason it does in the spend circuit: accepting  $pid$  as a free witness would sever the binding between the document and the tally chain the enrollment opens.

It outputs an enrollment nullifier  $E = P_2(DOM_{enr}, pid)$  together with a genesis tally commitment  $TalCom(pid, 0, d_{now}, r)$ . The pool rejects a duplicate  $E$ , which is what makes the enrollment one-per-document. The public trace is one opaque field element and one commitment, identical in shape for every holder. The residual metadata leak is the fact and timing of a single enrollment event per person, which batching and delay mitigate but do not eliminate.

## 4.5 The spend circuit

The spend circuit is where payment and compliance are welded together. With arity fixed at one payment input and two outputs (recipient and self-change), it proves:

1. **Payment validity.**  $pk_{self} = P_2(sk)$ ; the input commitment  $C_{in} = PayCom(v_{in}, pk_{self}, r_{in})$  is a member of the published root; the nullifier  $N_{pay} = Nul(sk, C_{in})$  is revealed; value is conserved,  $v_{in} = v_1 + v_2$  over 64-bit range-checked values; output commitments are well formed, with the change output committed under the in-circuit  $pk_{self}$  rather than a free witness key.
2. **Tally consume.** The prover supplies  $psec$  as a witness and the circuit *re-derives*  $pid$  from it. It then proves  $C_t^{old} = TalCom(pid, s_{old}, d_{old}, r_t)$  is a member of the root and reveals  $N_{tal} = Nul(psec, C_t^{old})$ . Re-deriving rather than accepting  $pid$  is essential: a free  $pid$  witness would let a prover consume a tally note while attributing the update to a different person.
3. **Tally update.** With  $d_{now} \geq d_{old}$  over 32-bit range-checked days,

$$s_{new} = \begin{cases} s_{old} + v_1 & \text{if } d_{now} = d_{old}, \\ v_1 & \text{otherwise (business-day reset),} \end{cases}$$

and  $C_t^{new} = TalCom(pid, s_{new}, d_{now}, r_t^{new})$  is published. Only  $v_1$ , the recipient output, is counted; self-change is not.

4. **Uniform disclosure memo.** With  $over = [s_{new} > T]$  and message

$$m = (over, over \cdot pid, over \cdot s_{new}, over \cdot d_{now}),$$

the circuit enforces  $(c_1, ct) = Enc_{APK}(m; r_{enc})$  as public output. Below threshold  $m$  is the all-zero message; above it, the true record.

**Pool acceptance rules.** The circuit proves a spend is well formed; it cannot prove the spend is well formed *against this pool*, because every public input listed above is a value the prover chose freely. Three of them must therefore be pinned to pool state on acceptance, and each closes an evasion that the proof alone permits.

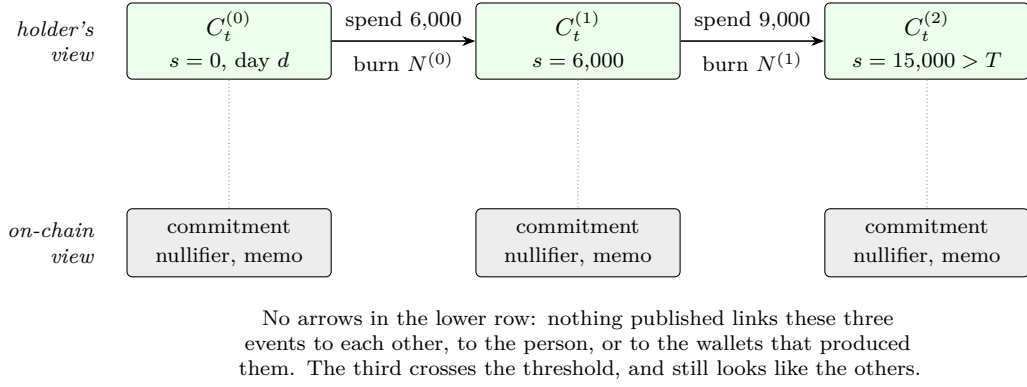


Figure 3: One person’s tally chain over three transactions. Above, the chain the holder can follow with `psec`; below, the same three events as everyone else sees them. The subtotal is carried in a commitment, so it is hiding, and each step is authorized by burning a nullifier rather than by naming a predecessor, so consecutive states cannot be joined. This is the pool’s existing note machinery applied to a note that holds a running total instead of a balance.

The day  $d_{\text{now}}$  must equal the pool’s current day. The circuit constrains only  $d_{\text{now}} \geq d_{\text{old}}$ , since it has no clock of its own; a payer sitting just below  $T$  could otherwise date the next spend tomorrow, take the business-day reset of the tally update above, and move a second near-threshold amount on the same real day under a dummy memo. The threshold  $t$  must equal the deployment’s  $T$ , or a prover declares  $T = 2^{64} - 1$  and never crosses it. And APK must match the configured auditor key on *both* coordinates: whenever  $(x, y)$  is on the curve so is  $(x, -y)$ , so pinning the abscissa alone admits a memo that satisfies the in-circuit encryption relation while decrypting, under the key the auditor actually holds, to garbage. That failure is silent in exactly the way that matters, since a real disclosure would be filed as a dummy. The pool additionally rejects a new tally commitment that already appears as a leaf, which is the degenerate spend  $v_1 = 0$  with  $r_t^{\text{new}} = r_t$  reissuing the note it consumes.

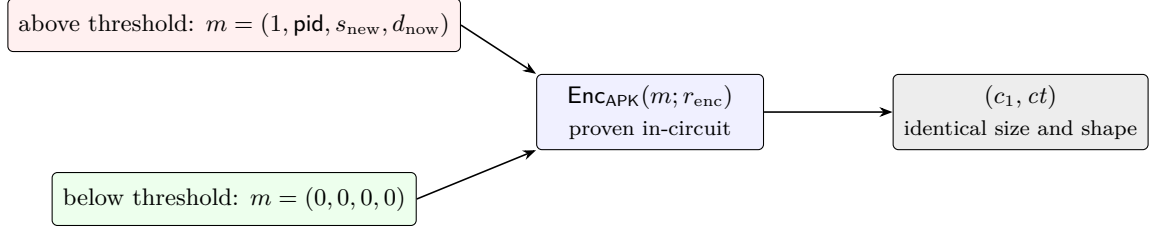
One further rule is required, and it is the one case where the circuit cannot stand in for the pool even in principle. The memo must be checked for structural validity on acceptance:  $c_1$  finite, on the curve, and canonically encoded, and every ciphertext limb reduced. A memo naming the point at infinity is otherwise admitted and then decrypts to nothing, so a payer owing a disclosure can file one that is accepted and unreadable, and an auditor processing a batch loses the honest records alongside it. This cannot be delegated to the proof, because the group element the circuit constrains and the group element the auditor decrypts are not the same object: the circuit’s abscissa-and-ordinate pair has no representation for the identity, so a memo can agree with the proof on both coordinates and still denote infinity to the implementation that reads it. The gap is in the encoding rather than in the statement, which is why binding the proof’s public inputs to the accepted record does not close it.

We state these as part of the construction rather than as implementation detail because the guarantees of Section 5 depend on them: without the day rule, the subtotal of a chain is not non-decreasing within a period, and without the key rule, disclosure correctness does not hold.

Figure 3 traces the tally chain these rules produce across three consecutive spends, set against what the same three transactions look like to everyone else.

#### 4.6 Why the memo must be uniform

If only above-threshold spends carried a memo, its presence would announce a crossing, and an observer could identify precisely the transactions the mechanism was designed to keep ordinary. Fixing the memo’s shape is therefore not an optimization but a requirement of the privacy argument. Every spend emits a ciphertext of identical size and structure, as shown in Figure 4;



One constraint system runs either way: 8,094 gates, 110 ms, a 14,656-byte proof. The branch is selected by witness values, not by circuit structure, so an observer sees no difference in the transaction, its cost, or its size.

Figure 4: The uniform disclosure memo. A threshold trigger that emitted a memo only when it fired would announce every crossing by the memo’s mere presence, making the compliance mechanism the leak it was meant to prevent. Both branches therefore encrypt a message of the same shape to the same key, and the circuit enforces correct encryption in both cases, so a prover cannot substitute noise for a report it owes.

only the auditor, decrypting all of them, distinguishes reports from dummies. This mirrors institutional practice, in which a bank observes every transaction and files a report on a subset, and it is the point at which our design departs from CAP [12], whose per-transaction trigger does not face the same cumulative-crossing side channel.

#### 4.7 Why the state lives in the pool’s tree

We considered two alternatives. An attester-managed state tree in the style of rotating-epoch-key systems introduces a party trusted for liveness and correctness, and its sybil resistance requires personhood gating at signup regardless, so it adds moving parts without removing an assumption. A rerandomizable updatable credential in the BBA+ [23] or UACS [24] style requires an issuer signature on each update; escaping that requires a threshold issuer committee, which is a registrar in a distributed costume and weakens exactly the claim we care about. Storing the tally in the pool’s own tree removes both: there is no party to trust because there is no party, and unlinkability is inherited rather than argued anew.

#### 4.8 What an observer sees

Per spend: two nullifiers, three fresh commitments, one memo, one proof, all of fixed shape. Per person, for their lifetime in the system: one enrollment event. The auditor additionally obtains records  $(\text{pid}, s, d)$  for above-threshold days. Since  $\text{pid}$  is a scoped hash of a secret, the auditor cannot invert it; converting a record into a legal identity requires compelling the person, which is the same procedural step a filed currency transaction report initiates.

### 5 Security Analysis

We sketch the arguments; full proofs are deferred.

**Theorem 1** (Person-binding). *Under collision resistance of  $P_2$ , soundness of the credential layer, and registry correctness, the number of live tally chains an adversary can maintain is at most the number of distinct pairs  $(\text{state}, \text{docnum})$  for which it can produce a document whose Passive Authentication chain verifies.*

*Proof sketch.* A live tally chain begins only at enrollment, which publishes  $E = P_2(\text{DOM}_{\text{enr}}, \text{pid})$  and is rejected on duplicate  $E$ . Two chains under one document therefore require two distinct

pid from one document. Since  $\text{pid} = P_2(P_2(\text{DOM}_{\text{pass}}, \text{state}, \text{docnum}), \text{APP\_SCOPE})$  is a deterministic function of the pair alone, and enrollment recomputes it from the DG1 bytes the credential proof commits to rather than accepting it as a witness, this requires a collision in  $P_2$ . Starting a chain without a document requires a proof of the statement of Section 4.2.3 for a chain terminating outside the registry, contradicting SNARK soundness, or an adversarial key inside it, contradicting registry correctness.  $\square$

*Remark 1* (The bound is on documents, not on humans). Theorem 1 bounds chains by valid documents, and the gap between that quantity and the number of humans is where this construction’s residual sybil surface lives in its entirety. Three routes widen it, and none is closed by cryptography. A dual national holds two genuine documents from two states and obtains two chains. A holder who reports a document lost obtains a replacement bearing a new *docnum*, and with it a new chain, on the issuing state’s timescale rather than on the ten-year expiry cycle. And a person who borrows another’s booklet can read its chip, because ICAO access control is keyed on data printed inside the document rather than on anything about its bearer. We regard the first as a genuine unsolved limitation, the second as rate-limited and evidence-generating rather than prevented, and the third as the reason sole possession appears as an explicit assumption in Section 3 rather than as a claim. What the theorem does establish is that the multiplier is bounded by documents a state actually issued, which is the property account-bound systems lack entirely: there, the multiplier is bounded by nothing.

**Theorem 2** (Limit soundness). *Under SNARK soundness, binding of the commitment scheme, collision resistance of  $P_2$ , and correctness of nullifier bookkeeping, Capita Protocol satisfies limit soundness.*

*Proof sketch.* Every accepted spend consumes a tally note and publishes its nullifier, so the tally notes reachable by one person form a chain, not a tree: reuse is rejected by the nullifier set. Within a period, the chain’s subtotal is non-decreasing and increases by exactly the counted output  $v_1$  of each spend, which the circuit enforces together with  $v_{\text{in}} = v_1 + v_2$  under 64-bit range checks. Non-decrease within a period is where the pool’s day rule is load-bearing rather than administrative: the circuit permits any  $d_{\text{now}} \geq d_{\text{old}}$ , so it is the acceptance rule  $d_{\text{now}} = \text{currentDay}$  that prevents a prover from claiming a period boundary that has not occurred and resetting the subtotal at will. The range checks are load-bearing rather than defensive; see Remark 2. Consequently the total counted value moved by one credential in a period exceeds  $T$  only after some spend produces  $s_{\text{new}} > T$ , at which point the circuit is satisfiable only with a memo encrypting the true record. Summing over  $q$  credentials gives the bound.  $\square$

*Remark 2* (Range checks are load-bearing). Omitting the range check on  $v_1$  does not merely weaken a bound; it inverts the mechanism. A prover could choose  $v_1 = -100$  and  $v_2 = v_{\text{in}} + 100$  in  $\mathbb{F}_p$ , satisfying value conservation while *decreasing* the running subtotal and minting value. During development, deleting this single constraint left the entire test suite passing, which is why our implementation pins each soundness constraint with a test that fails when the constraint is removed.

**Lemma 1** (Threshold correctness, with precondition). *For  $s_{\text{new}} < 2^{129}$ , an accepting assignment exists only if the memo encrypts the message determined by the predicate  $s_{\text{new}} > T$ .*

*Proof sketch.* The comparison is realized by a hinted boolean pinned by a muxed 129-bit range check. The argument establishes the equivalence only when the operand lies below  $2^{129}$ ; in the top slice of the field the dummy branch is also satisfiable. The precondition is discharged by construction rather than assumed: subtotals enter the tree at 0 on enrollment, each spend adds  $v_1 < 2^{64}$ , and a depth-16 tree admits at most  $2^{16}$  notes, so every reachable subtotal is below  $2^{80}$  by induction. To keep circuit-local soundness independent of pool admission discipline, the implementation additionally range-checks  $s_{\text{old}}$  to 128 bits, so a forged tally note with  $s_{\text{old}} =$

$p - 50$ , which would otherwise wrap the updated subtotal to a small value and silently reset the limit, is rejected inside the proof rather than relying on the pool to have never admitted it.  $\square$

We state Lemma 1 with its precondition deliberately. An earlier version of our implementation documented the gadget as sound for all field elements; it is not, and a theorem asserting otherwise would have been false in print.

**Theorem 3** (Unlinkability). *Under hiding of the commitment scheme, pseudorandomness of the nullifier derivation, and IND-CPA security of the memo encryption, Capita Protocol satisfies unlinkability.*

*Proof sketch.* A hybrid argument. Commitments are replaced by commitments to independent values, indistinguishable by hiding. Nullifiers are replaced by uniform field elements, indistinguishable by pseudorandomness, using that each nullifier is evaluated at a distinct commitment and thus never repeats. Memos are replaced by encryptions of the all-zero message, indistinguishable by IND-CPA; this step is where uniformity is required, since the reduction needs challenge ciphertexts of identical shape in both worlds. The remaining view is independent of  $b$ . Tally notes contribute nothing extra because they are, by construction, commitments and nullifiers of the same form as monetary notes.  $\square$

**Theorem 4** (Disclosure correctness). *Under SNARK soundness and correctness of the encryption gadget, Capita Protocol satisfies disclosure correctness.*

*Proof sketch.* Immediate from Lemma 1 together with in-circuit enforcement of the encryption relation, which binds the ciphertext to the same  $\text{pid}$ ,  $s_{\text{new}}$ , and  $d_{\text{now}}$  that the published tally commitment binds.  $\square$

## 6 Implementation and Evaluation

### 6.1 Implementation

We implement Capita Protocol in Noir with the Barretenberg proving backend (UltraHonk) [34], comprising a shared circuit library, an enrollment circuit, and a spend circuit, alongside an independent TypeScript reference implementation of the same protocol. The two implementations are not client and server; they are two implementations of one specification, cross-checked by a consistency circuit and test suite, so that a mistake in either surfaces as disagreement rather than as silence. The prototype comprises approximately 1,200 lines of Noir and 780 lines of TypeScript, with 1,460 lines of tests: 79 tests in total, of which 36 are circuit tests and 43 are harness and integration tests.

Soundness constraints are held to an explicit bar: every constraint that prevents an attack is pinned by a test that fails when the constraint is deleted. This bar has a blind spot that is worth reporting because it is a property of the toolchain rather than of our code. Noir elides range checks whose witness feeds a black-box operation; two `assert_max_bit_size` calls in our encryption gadget emitted no constraints at all while appearing correct in source, and deleting them changed nothing observable, because there was nothing to delete. A delete-and-observe methodology cannot detect an absent constraint. We addressed this by inspecting the compiled ACIR of the spend circuit directly and asserting that every scalar witness feeding its multi-scalar multiplications carries its own range opcode. The check is scoped to the circuit we prove; a test-only consistency probe in the same repository still exhibits the elision, harmlessly, since it is never proven.

| Circuit    | Gates | ACIR opcodes | Brillig opcodes | Public inputs |
|------------|-------|--------------|-----------------|---------------|
| Enrollment | 322   | 14           | 0               | 3             |
| Spend      | 8,094 | 273          | 87              | 16            |

Table 2: Circuit sizes. The spend circuit includes payment validity, Merkle membership for two notes at depth 16, tally consume and update, the threshold comparison, and in-circuit hash-ElGamal encryption of the disclosure memo.

| Circuit                | Prove (ms)          | Verify (ms) | Proof (bytes) | VK (bytes) |
|------------------------|---------------------|-------------|---------------|------------|
| Enrollment             | 47.4 [46.5–48.0]    | 2.73        | 14,656        | 3,680      |
| Spend, below threshold | 110.1 [107.9–115.4] | 2.75        | 14,656        | 3,680      |
| Spend, above threshold | 110.2 [108.6–112.4] | 2.74        | 14,656        | 3,680      |

Table 3: Proving and verification cost, median of 10 repetitions with min–max range for proving. Proof size is constant under UltraHonk and independent of threshold position.

## 6.2 Methodology

Measurements were taken on an Apple M4 Max with 14 cores and 36 GB of memory, running macOS 26.5.2, with `nargo` 1.0.0-beta.22, Barretenberg 5.0.0-nightly.20260522, and Node.js 22.14.0. Circuit sizes are reported by the backend’s gate counter. Proving and verification are measured over 10 repetitions, reporting the median, after one untimed warm-up iteration that absorbs one-time reference-string loading and runtime initialization; reporting the warm-up as a per-transaction cost would overstate it. Verification is measured against a precomputed verification key, since key computation is a per-circuit deployment step rather than a per-proof cost. Witnesses are generated from live pool state through the full enroll, deposit, and spend flow rather than synthesized, so the figures reflect real transactions including Merkle membership, tally update, and memo encryption. All proofs verified.

## 6.3 Results

Tables 2 and 3 report the results. Three observations matter.

First, the cost is modest. A spend circuit that carries a full compliance mechanism in addition to a shielded payment is 8,094 gates and proves in roughly a tenth of a second on a laptop-class machine, with verification at 2.7ms and a constant 14.7kB proof. Person-bound limits are not, on this evidence, expensive.

Second, and more important for the privacy argument, the below-threshold and above-threshold spends cost 110.1ms and 110.2ms respectively, a difference well inside run-to-run variation with overlapping min–max ranges, and produce byte-identical proof and memo sizes. This is the expected consequence of the uniform-memo design, which executes one constraint system regardless of threshold position, but it is worth measuring rather than assuming: a timing or size gap correlated with threshold crossing would be a privacy defect that no amount of ciphertext indistinguishability would repair.

Third, enrollment is cheap enough to be unremarkable at 322 gates, which matters because enrollment is the one event per person that is visible as such.

## 6.4 Projected cost of the credential layer

Tables 2 and 3 measure the accounting and disclosure machinery specified in Sections 4.3 through 4.6. They do not measure the passport verification circuits of Section 4.2.3, for which we give projections from published figures for deployed systems rather than measurements of our



own. We separate the two rather than combining them because a projection and a measurement are different kinds of claim and a reader is entitled to know which is which.

Two things make the projection reasonably tight. ZKPassport verifies exactly the chain of Section 4.2.1 on consumer phones, and does so in Noir with the Barretenberg backend producing UltraHonk proofs [15], which is the identical proving stack this work uses; its reported costs therefore transfer without a change of proof system. It reports base proofs, generated once per document and cached, at ten to fifty seconds on-device, varying with the issuing state’s signature algorithm and the handset, and subsequent disclosure proofs at under one second to ten seconds. Independently, mobile proving benchmarks for an RSA PKCS#1 v1.5 circuit with SHA-256 report roughly 6.5s natively on an iPhone 14 Pro Max [16].

Three consequences follow for a deployment. The expensive work is one-time:  $\mathcal{C}_{\text{csca}}$  and  $\mathcal{C}_{\text{sod}}$  are proved once per document and cached, so the recurring per-transaction cost remains the spend circuit measured above, and enrollment is the only operation a user experiences as slow. Cost is not uniform across holders, because it tracks the issuing state’s algorithm choice, which is precisely the correlation that motivates the uniformity mechanism of Section 4.2.7; note that mechanism equalizes the *observable* interface rather than the proving time, so a determined adversary with timing access retains a signal that batching and deferred submission, not circuit structure, must address. And memory, not time, is the binding constraint on older hardware: the same benchmarks record an RSA circuit requiring on the order of 5GB and failing on handsets that cap application memory near 3GB [16], so a deployment must either restrict itself to devices above that bound or offload proving.

## 6.5 Threats to validity

Three limits bound what the numbers above can be taken to show. First and most important, the credential-layer costs of Section 6.4 are projections from published figures for comparable systems, not measurements of our implementation of Section 4.2.3; they should be read as an argument that the layer is affordable on the stated stack, not as a report of what ours costs. Second, we measure a prototype pool in a test harness rather than integration with a production pool, so the figures exclude on-chain verification gas and state-management overhead. Third, all measurements come from a single machine and a single hardware architecture, so they establish an order of magnitude rather than portable constants. None of the three affects the security arguments of Section 5, which are stated over the abstract construction rather than over any implementation of it.

## 7 Discussion

**What is not claimed.** Threshold-triggered disclosure is not new [6, 7, 8, 12]. Verifying an ICAO passport chain in zero knowledge is not new [19, 15]; Section 4.2 specifies rather than invents it, and the one part we do claim there is the observation and repair of the algorithm-variant leak in Section 4.2.7. Unlinkable value accumulation is not new [23, 24]. The contribution is the composition and the specific mechanism that makes it non-trivial, namely pool-native tally notes with uniform memos.

**Multiple citizenship.** A person holding two passports obtains two limit slots, hence  $2T$ . This is bounded, acknowledged, and unsolved by every personhood system we are aware of. Cross-document deduplication would require exactly the cross-state identity infrastructure the design exists to avoid.

**Replacement and borrowed documents.** Remark 1 states the two remaining routes from documents to identities, and both deserve the plain version. A holder who reports a passport

lost receives a replacement bearing a new document number, and with it a fresh limit, on a timescale set by the issuing state rather than by the ten-year expiry cycle; the defence is that each instance costs a genuine application to a state that keeps records of exactly this pattern, so the attack is rate-limited and evidence-generating rather than prevented. A holder who borrows another person’s booklet can read its chip, because the access key of Section 4.2.2 is derived from the data page rather than from anything about the bearer, so what the credential layer proves is possession rather than ownership. Biometric comparison against DG2 would narrow this, at the price of introducing exactly the biometric processing that a privacy-motivated design should be reluctant to require, and we do not adopt it.

**Who is excluded.** The construction inherits the coverage of the credential it consumes, and passport coverage is deeply unequal. In several populous states, including India, chip-bearing documents were introduced only recently and non-chip passports remain valid until they expire, so for years to come a majority of nationals cannot enroll at all. A limit regime that only the passport-holding minority can participate in is not a neutral technical artifact, and we do not present universal deployment as near. The mitigation is architectural rather than rhetorical: the credential layer is decoupled from the accounting layer through a single field element, so any credential admitting a deterministic per-person secret substitutes without touching the construction. National digital identity schemes with government-signed attributes, of which India’s is the largest, are the obvious candidate, and supporting one alongside passports is the most consequential piece of future work in this paper.

**Consenting proxies.** A person routing spends through another consenting person’s allowance is a conspiracy of humans, addressed by law rather than cryptography. The system still bounds total flow to  $q \cdot T$  for  $q$  participating humans, which we state as a property rather than conceal as a defect: it is precisely the guarantee the banking rule provides, since a bank likewise cannot prevent one customer from asking another to make a deposit.

**Coercion and the persistent-state objection.** Friolo et al. [32] hold that a payer should not have to carry secrets from one transaction to the next, citing asset-storage security and the use of blackmail or coercion to extract payment history. Capita Protocol violates that principle by construction: the tally note is precisely such a carried secret, and honesty requires treating this as a real cost rather than a presentational detail. Three things bound it. The state is self-custodied rather than deposited with an operator, so there is no aggregated target to compromise. It is unlinkable to observers, so it does not mark its holder in the interim. And what compulsion yields is one person’s own spending history, not a graph implicating counterparties. None of this eliminates the risk: a party who compels a person to surrender psec learns that history. We record it as a genuine residual cost of person-bound limits, and observe that the deployed alternative, a central registry, exposes the same history to a far wider set of parties with no coercion required at all.

**The pseudonymity objection.** A recurring critique of one-per-person identity systems is that they collapse pseudonymity: if everyone has exactly one identity, everyone is trackable. Our answer is structural. A person holds one *limit*, but arbitrarily many unlinkable accounts, and the per-person state is never visible as a repeated value. What is unique is a quantity nobody can observe.

**Concurrency and deployment.** One tally chain per person serializes that person’s spends, which a wallet can order but which becomes a genuine constraint for high-frequency use. Sharding the tally into per-person sub-chains, at the cost of a weaker bound, is the natural remedy and is future work.

## 8 Conclusion and Future Work

We have shown that a regulatory requirement usually taken to demand a central registry, namely per-person aggregation of transaction volume, can instead be met cryptographically, in a permissionless shielded pool, with no registrar and no persistent linkable identifier. The mechanism is a per-person tally note living in the payment pool’s own commitment tree, updated by every spend from every wallet the person controls, paired with a uniform disclosure memo that prevents the compliance mechanism from becoming the very side channel it was meant to avoid. A working implementation shows the cost is roughly one tenth of a second of proving for a complete spend, with threshold position not observable in either timing or size.

Several directions remain. The credential layer is specified in Section 4.2 but its circuits are not yet measured in our implementation, and reporting them alongside the accounting figures is the immediate next step. Supporting a national digital identity scheme alongside passports would address the coverage gap that Section 7 concedes is the construction’s sharpest practical limitation. Rolling-window accounting, in which the tally note carries a vector of day buckets rather than a single day, would close the boundary case in which a person spends  $T$  shortly before and shortly after a period rollover; we note that this behavior is compliant under the business-day semantics of [1], so the extension tightens a rule rather than fixing a defect. Threshold distribution of the auditor key, receive-side aggregation, credential revocation, and additional credential types such as national digital identity schemes are all natural extensions. Finally, a full simulation-based treatment in the universal composability framework would strengthen the game-based analysis given here.

**Availability.** The implementation, specification, and benchmark harness are available at <https://github.com/yashhzd/capita>.

## References

- [1] U.S. Code of Federal Regulations, Title 31 §1010.313, *Aggregation*. Financial Crimes Enforcement Network.
- [2] Financial Crimes Enforcement Network. *Requirements for Certain Transactions Involving Convertible Virtual Currency or Digital Assets*. Notice of Proposed Rulemaking, 85 FR 83840, December 2020.
- [3] European Commission. *Proposal for a Regulation of the European Parliament and of the Council on the establishment of the digital euro*, COM(2023) 369 final, 28 June 2023. Article 16(1) (holding limits); Article 35(8) (single access point of user identifiers).
- [4] European Data Protection Board and European Data Protection Supervisor. *EDPB-EDPS Joint Opinion 02/2023 on the Proposal for a Regulation of the European Parliament and of the Council on the establishment of the digital euro*, adopted 18 October 2023.
- [5] D. Hopwood, S. Bowe, T. Hornby, and N. Wilcox. *Zcash Protocol Specification*. Electric Coin Company.
- [6] J. Camenisch, S. Hohenberger, and A. Lysyanskaya. Balancing accountability and privacy using e-cash (extended abstract). In *Security and Cryptography for Networks (SCN)*, LNCS 4116, pages 141–155. Springer, 2006.
- [7] C. Garman, M. Green, and I. Miers. Accountable privacy for decentralized anonymous payments. In *Financial Cryptography and Data Security (FC)*, 2016. Cryptology ePrint Archive, Report 2016/061.

- [8] K. Wüst, K. Kostiaainen, V. Capkun, and S. Capkun. PRCash: Fast, private and regulated transactions for digital currencies. Cryptology ePrint Archive, Report 2018/412, 2018.
- [9] K. Wüst, K. Kostiaainen, N. Delius, and S. Capkun. Platypus: A central bank digital currency with unlinkable transactions and privacy preserving regulation. In *ACM CCS*, 2022. Cryptology ePrint Archive, Report 2021/1443.
- [10] A. Sarencheh, A. Kiayias, and M. Kohlweiss. PEReDi: Privacy-enhanced, regulated and distributed central bank digital currencies. In *ACM CCS*, 2022. Cryptology ePrint Archive, Report 2022/974.
- [11] A. Tomescu, A. Bhat, B. Applebaum, I. Abraham, G. Gueta, B. Pinkas, and A. Yanai. UTT: Decentralized ecash with accountable privacy. Cryptology ePrint Archive, Report 2022/452, 2022.
- [12] Espresso Systems. *Configurable Asset Privacy (CAP)*. <https://github.com/EspressoSystems/cap>, 2022.
- [13] International Civil Aviation Organization. *Doc 9303, Machine Readable Travel Documents*, Eighth Edition, 2021. Part 10 (logical data structure), Part 11 (security mechanisms), Part 12 (public key infrastructure).
- [14] R. Housley. *Cryptographic Message Syntax (CMS)*. RFC 5652, Internet Engineering Task Force, September 2009.
- [15] ZKPassport. *Documentation and circuits for passport and national ID zero-knowledge proofs*. <https://docs.zkpassport.id>, and <https://github.com/zkpassport/circuits>.
- [16] Mopro contributors. *Mobile proving performance and benchmarks*. <https://zkmopro.org/docs/performance/>.
- [17] C. Beer, S. Zingg, K. Kostiaainen, K. Wüst, V. Capkun, and S. Capkun. PayOff: A regulated central bank digital currency with private offline payments. arXiv:2408.06956, 2024.
- [18] C. Badertscher, M. Sedaghat, and H. Waldner. Unlinkable policy-compliant signatures for compliant and decentralized anonymous payments. Cryptology ePrint Archive, Report 2023/1070, 2023.
- [19] M. Rosenberg, J. White, C. Garman, and I. Miers. zk-creds: Flexible anonymous credentials from zkSNARKs and existing identity infrastructure. In *IEEE Symposium on Security and Privacy*, 2023. Cryptology ePrint Archive, Report 2022/878.
- [20] E. Crites, A. Kiayias, M. Kohlweiss, and A. Sarencheh. SyRA: Sybil-resilient anonymous signatures with applications to decentralized identity. In *ACM CCS*, 2025. Cryptology ePrint Archive, Report 2024/379.
- [21] J. Burdges, O. Ciobotaru, H. Kılınç Alper, A. Stewart, and S. Vasilyev. Ring verifiable random functions and zero-knowledge continuations. Cryptology ePrint Archive, Report 2023/002, 2023.
- [22] A. R. Choudhuri, S. Garg, K. Lee, H. Montgomery, G. V. Policharla, and R. Sinha. A cryptographic framework for proof of personhood. Cryptology ePrint Archive, Report 2026/333, 2026.
- [23] G. Hartung, M. Hoffmann, M. Nagel, and A. Rupp. BBA+: Improving the security and applicability of privacy-preserving point collection. In *ACM CCS*, 2017.

- [24] J. Blömer, J. Bobolz, D. Diemert, and F. Eidens. Updatable anonymous credentials and applications to incentive systems. Cryptology ePrint Archive, Report 2019/169, 2019. In *ACM CCS*, 2019.
- [25] R. Chairattana-Apirom, N. Döttling, A. Lysyanskaya, and S. Tessaro. Everlasting anonymous rate-limited tokens. In *ASIACRYPT*, 2025. Cryptology ePrint Archive, Report 2025/1030.
- [26] G. Papadoulis, D. Balla, P. Grontas, and A. Pagourtzis. AQQUA: Augmenting Quisquis with auditability. In *Applied Cryptography and Network Security (ACNS)*, 2025. Cryptology ePrint Archive, Report 2024/1181.
- [27] M. Bruguères, V. Languille, P. Kuznetsov, and H. Zarfaoui. Fast, private and regulated payments in asynchronous networks. In *Advances in Financial Technologies (AFT)*, 2025. Cryptology ePrint Archive, Report 2025/098.
- [28] R. Gao. Invisible warning line: Efficient and generic regulation for anonymous cryptocurrencies. Cryptology ePrint Archive, Report 2023/1138, 2023.
- [29] A. Sarencheh, H. Khoshakhlagh, A. Kavousi, and A. Kiayias. DART: Decentralized, anonymous, and regulation-friendly tokenization. Cryptology ePrint Archive, Report 2025/239, 2025.
- [30] M. Nardelli, F. De Sclavis, and M. Iezzi. A hitchhiker’s guide to privacy-preserving digital payment systems: A survey on anonymity, confidentiality, and auditability. arXiv:2505.21008, 2025.
- [31] P. Chatzigiannis, F. Baldimtsi, and K. Chalkias. SoK: Auditability and accountability in distributed payment systems. Cryptology ePrint Archive, Report 2021/239, 2021.
- [32] D. Friolo, G. Goodell, D. Toliver, and H. D. Nakib. Private electronic payments with self-custody and zero-knowledge verified reissuance. arXiv:2409.01958, 2024.
- [33] L. Grassi, D. Khovratovich, and M. Schofnegger. Poseidon2: A faster version of the Poseidon hash function. In *AFRICACRYPT*, 2023. Cryptology ePrint Archive, Report 2023/323.
- [34] Aztec Labs. *Noir: A domain-specific language for zero-knowledge proofs*, and the Barretenberg proving backend. <https://noir-lang.org>.